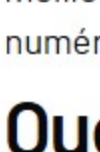


Meilleures pratiques en matière de sécurité Active Directory

Sécurité d'Active Directory • Lire 8 MIN

- Quelles sont les meilleures pratiques en matière de sécurité AD ?
- 1. Maintenir un nombre restreint d'utilisateurs privilégiés
- 2. Utiliser des groupes pour attribuer des privilèges
- 3. Sécuriser les comptes avec des privilèges d'administrateur
- 4. Appliquer des politiques modernes en matière de mots de passe
- 5. Appliquer des mots de passe robustes aux comptes de service



Sean Deuby | Technologie principal, Amériques

Au sein de votre infrastructure informatique, Active Directory (AD) est le pivot central du contrôle de l'accès aux ressources et du fonctionnement de votre entreprise. Cependant, l'importance d'Active Directory pour votre organisation le place dans la ligne de mire des acteurs de la menace. En cas de violation d'Active Directory, les attaquants peuvent mettre la main sur des informations d'identification privilégiées et potentiellement compromettre la sécurité des données de l'entreprise ou affecter les applications. La mise en œuvre des meilleures pratiques en matière de sécurité de l'Active Directory est donc un élément important de la planification d'une politique de sécurité numérique.

Quelles sont les meilleures pratiques en matière de sécurité Active Directory ?

Protéger Active Directory, c'est rendre la vie aussi difficile que possible aux cyberattaquants. Ces 12 meilleures pratiques de sécurité Active Directory peuvent vous aider à réduire le risque de violation de la sécurité et à accroître votre cyber-résilience. L'objectif : **réduire la surface d'attaque pour protéger et renforcer votre environnement Active Directory**.

- Maintenir un nombre minimal d'utilisateurs privilégiés.
- Les groupes permettent d'attribuer des privilèges.
- Sécuriser les comptes avec des privilèges d'administrateur.
- Appliquer des politiques modernes en matière de mots de passe.
- Renforcer les mots de passe pour les comptes de service.
- Effectuer des évaluations régulières pour détecter les violations de la politique en matière de mots de passe.
- Désactiver le service Print Spooler.
- Désactiver Server Message Block v1 (SMBv1) et restreindre New Technology LAN Manager (NTLM).
- Restreindre l'accès aux contrôleurs de domaine (DC).
- Planifier la récupération d'Active Directory.
- Utiliser le filtrage des SID dans toutes les forêts.
- Surveiller Active Directory pour détecter les activités suspectes et les configurations non sécurisées.

Prêt à commencer ?

1. Maintenir un nombre minimal d'utilisateurs privilégiés

Les utilisateurs disposant de privilèges excessifs remettent directement en question les exigences en matière de sécurité et de conformité réglementaire. S'ils sont compromis, ces comptes permettent aux pirates de s'implanter plus facilement dans votre environnement. La gestion des utilisateurs privilégiés est un élément essentiel de la gestion globale d'Active Directory, mais elle peut également prendre beaucoup de temps. Les grandes entreprises peuvent avoir des centaines de comptes dans des groupes privilégiés.

Certains comptes peuvent se voir accorder des autorisations excessives pour faire fonctionner rapidement de nouvelles applications. D'autres peuvent avoir hérité d'autorisations dont ils n'ont plus besoin. Si vous êtes responsable de l'octroi des accès, vous devez comprendre le principe du moindre privilège et l'utiliser pour déterminer les autorisations dont chaque utilisateur ou groupe a besoin pour faire son travail efficacement.

Commencez par examiner les groupes suivants afin de vérifier que chaque membre a une raison légitime d'en faire partie :

- Administrateurs d'entreprise
- Administrateurs de schémas
- Admins de domaine
- Opérateurs de compte (le cas échéant)
- Opérateurs de serveur (le cas échéant)
- Opérateurs d'impression (le cas échéant)

- Administrateurs DHCP
- DNSAdmins

2. Utiliser des groupes pour attribuer des privilèges

L'utilisation de groupes simplifie le processus d'attribution des autorisations aux utilisateurs. Plutôt que de gérer les autorisations individuellement (ce qui peut entraîner des erreurs), organisez les utilisateurs en groupes, puis attribuez les autorisations appropriées à ces groupes.

Un ensemble d'utilisateurs peut représenter une unité opérationnelle ou une équipe interne dans laquelle les utilisateurs ont des besoins identiques en matière de droits d'accès. Déterminer qui doit appartenir à chaque groupe (par exemple, qui sert d'administrateur de domaine ou d'administrateur de schéma) et quels droits ces groupes doivent avoir nécessite une communication entre l'équipe de gestion d'Active Directory et les parties prenantes de l'entreprise.

3. Sécuriser les comptes avec des privilèges d'administrateur

Lorsqu'un domaine est créé dans Active Directory, le compte Administrateur local devient le compte de domaine Administrateur et un membre par défaut des groupes Admins de domaine et Administrateurs du domaine. Si le domaine est le domaine racine de la forêt, le compte devient également membre du groupe Enterprise Admins.

Pour protéger ce compte, Microsoft recommande d'activer l'indicateur "Le compte est sensible et ne peut pas être délégué". Vérifiez également que les objets de stratégie de groupe (GPO) sont configurés de manière à limiter l'utilisation des comptes Administrateur de domaine et Administrateur intégré sur les systèmes reliés à un domaine. Plus précisément, bloquez l'utilisation de ces comptes :

- Accès aux serveurs et postes de travail des membres
- Se connecter en tant que travailleur par lots
- Se connecter en tant que service
- Accès aux serveurs et postes de travail des membres à l'aide des services de bureau à distance

4. Appliquer des politiques modernes en matière de mots de passe

Au centre de chaque attaque d'entreprise ou brèche de sécurité, il y a souvent un mot de passe volé. En plus d'utiliser ces identifiants pour l'accès initial, les acteurs de la menace peuvent les utiliser pour se déplacer latéralement dans l'environnement compromis.

C'est pourquoi la sécurité des mots de passe est primordiale. Cependant, l'expérience des grands fournisseurs de services en nuage a montré que les politiques de mot de passe traditionnelles sont inadéquates contre les attaques modernes. Le NIST et d'autres grandes organisations ont mis à jour leurs politiques de mots de passe pour tenir compte de cette réalité.

Les attaques par force brute contre les services en ligne ont diminué. Elles ont été remplacées par des attaques par pulvérisation de mots de passe, dans lesquelles des mots de passe communs bien connus sont tentés contre de nombreux utilisateurs d'une organisation. Ces attaques sont désormais courantes et souvent couronnées de succès. Les attaques par pulvérisation de mots de passe exploitent la tendance des utilisateurs à créer des mots de passe faciles à retenir et à deviner.

Une meilleure stratégie consiste à se concentrer d'abord sur l'élimination des mots de passe courants d'Active Directory. Cela peut être réalisé avec des filtres de mots de passe tiers ou avec Microsoft Azure AD Password Protection.

La deuxième étape d'une politique de mot de passe solide consiste à reconnaître que l'application de la complexité peut conduire à des mots de passe que les utilisateurs ne peuvent pas retenir et à des modèles facilement reconnaissables que les attaquants peuvent rapidement déchiffrer. Il convient plutôt d'encourager la longueur des mots de passe ou des phrases de passe, avec l'ajout de chiffres et de caractères spéciaux, afin d'obtenir des mots de passe faciles à mémoriser pour les utilisateurs, mais difficiles à deviner pour les pirates.

Par exemple, le mot de passe **Implicite-Research-Uncooked** peut être mémorisé facilement mais (selon l'outil de force de mot de passe Bitwarden) il faudrait des siècles pour le craquer. Les sources en ligne et les principaux gestionnaires de mots de passe permettent d'utilitaires permettant de générer des phrases de passe. L'utilisateur peut simplement continuer à générer des phrases jusqu'à ce qu'il trouve un mot de passe dont il se souvient.

Enfin, il est déconseillé d'oviger l'expiration des mots de passe. L'expérience a montré que la rotation force les utilisateurs à adopter des méthodes de mots de passe faciles à décrypter. Si une organisation a été victime d'une intrusion ou si les informations d'identification d'un utilisateur ont été compromises, les mots de passe doivent être mis à jour. Dans le cas contraire, ne les modifiez pas.

Mettez en œuvre simultanément tous ces contrôles : interdiction des mots de passe courants, réduction de la complexité, augmentation de la longueur et désactivation de l'expiration des mots de passe. Sinon, vous risquez de créer des mots de passe facilement craquables.

Une autre bonne pratique : tirez parti de la fonctionnalité de politique de mot de passe à granularité fine. Bien que les administrateurs puissent utiliser la stratégie de domaine par défaut pour définir une politique de mot de passe unique pour tous les membres du domaine, les stratégies de mot de passe fines permettent aux administrateurs de définir des mots de passe plus stricts pour les utilisateurs individuels et les groupes globaux.

5. Appliquer des mots de passe robustes aux comptes de service

La "Kerberoasting" est le moyen le plus courant de compromettre un compte privilégié et de prendre le contrôle d'un serveur Active Directory. Les attaques de type "Kerberoasting" sont en augmentation, certaines estimations faisant état d'une hausse de plus de 500 % depuis le début de l'année 2022.

Dans cette technique, un acteur de la menace commence par obtenir l'accès d'un utilisateur normal par le biais d'un hameçonnage ou d'une autre méthode. Avec cet accès, l'attaquant peut facilement obtenir une liste de comptes de service en énumérant les noms des principaux services (SPN) dans Active Directory.

Ensuite, l'attaquant établit une corrélation entre ces comptes et l'appartenance à des groupes privilégiés afin d'obtenir une liste de comptes de service privilégiés. L'acteur de la menace demande ensuite un ticket de service Kerberos à l'un de ces comptes privilégiés. Ce ticket est chiffré avec le hachage du mot de passe du compte de service, que l'attaquant peut généralement déchiffrer hors ligne.

Avec le hachage du mot de passe du compte de service, l'acteur de la menace peut rapidement prendre le contrôle d'Active Directory. Une attaque Kerberoasting réussie peut compromettre une forêt Active Directory en quelques minutes.

Le seul moyen de lutter contre une attaque de type "Kerberoasting" est de rendre les mots de passe des comptes de service extrêmement difficiles à déchiffrer :

- Utilisez un minimum de 25 caractères.
- Utilisez un générateur de mot de passe pour créer un mot de passe long, complexe et hautement entropique et stockez-le dans un coffre-fort pour mot de passe.
- Envisagez d'utiliser un compte de service géré par groupe (gMSA) qui effectue automatiquement une rotation des mots de passe complexes. (Assurez-vous d'abord de bien connaître les **vulnérabilités** potentielles **liées aux gMSA**).

6. Effectuer des évaluations régulières pour détecter les violations de la politique en matière de mots de passe

L'examen régulier des politiques et des paramètres relatifs aux mots de passe permet de détecter les problèmes susceptibles d'exposer Active Directory à des attaques. Par exemple, examinez attentivement tout compte pour lequel l'indicateur PASSWD_NOTREQD est activé. En outre, examinez les comptes dont l'accès anonyme à Active Directory est activé, ce qui permet aux utilisateurs non authentifiés d'interroger Active Directory.

7. Désactiver le service Print Spooler

Le service Print Spooler gère les processus d'impression et est exécuté par défaut sur les clients et les serveurs Windows. Bien que cela semble correct à première vue, tout utilisateur authentifié peut se connecter à distance au service, demander une mise à jour des nouveaux travaux et demander au DC d'envoyer la notification au système avec une délégation sans contrainte. Cela expose les informations d'identification du compte de l'ordinateur du DC. **En raison du risque**, la meilleure pratique consiste à désactiver le service sur tous les DC.

8. Désactiver SMBv1 et restreindre NTLM

Les DC qui activent le protocole SMBv1 sont également à risque. Microsoft a supprimé en 2014 le protocole SMBv1, qui est vulnérable à de nombreuses attaques, et recommande de le désactiver.

De même, restreindre l'utilisation de NTLM. De nombreuses organisations tardent à désactiver NTLM en raison de l'impact que cette action peut avoir. Cependant, les responsables informatiques devraient **envisager de limiter son utilisation** autant que possible.

9. Restreindre l'accès aux contrôleurs de domaine

Les organisations doivent restreindre l'accès aux **contrôleurs de domaine** afin de limiter le risque de compromission du DC par des logiciels malveillants :

- La navigation sur Internet ne doit pas être autorisée sur le DC.
- Les GPO liés à toutes les unités d'organisation DC d'une forêt ne doivent être définis que pour autoriser les connexions RDP (Remote Desktop Protocol) à partir d'utilisateurs et de systèmes autorisés.

10. Planifier la récupération d'Active Directory

L'établissement d'un plan de **restauration** complet et détaillé de l'**Active Directory** est un élément essentiel du renforcement de la cyber-résilience. Les organisations devraient sauvegarder au moins deux DC par domaine, y compris le domaine racine. Ces sauvegardes doivent être conservées hors ligne pour éviter qu'elles ne soient infectées par des logiciels malveillants.

11. Utiliser le filtrage des SID dans toutes les forêts.

Pour comprendre l'importance du filtrage des SID en matière de sécurité, examinons la manière dont le contrôle d'accès à Active Directory est géré entre les forêts.

Un Forest Trust relie deux forêts Active Directory pour permettre aux utilisateurs d'une forêt d'accéder aux ressources de l'autre. Les trusts de forêt sont essentiels pour maintenir l'accès dans une organisation comportant plusieurs forêts. Dans un scénario courant, les utilisateurs d'une forêt de comptes centralisée accèdent à des applications (telles que des serveurs de fichiers ou des serveurs SharePoint) dans une ou plusieurs forêts de ressources.

Chaque utilisateur, groupe ou ordinateur (connu sous le nom de "security principals") dans un domaine et une forêt Active Directory possède un identifiant de sécurité (SID) unique. Cet identifiant est utilisé dans le jeton d'accès de l'utilisateur pour accorder l'accès aux ressources dans toute la forêt à l'aide de listes de droits de contrôle d'accès (ACL).

J'ai rencontré un problème lié au SID chez Intel alors que je testais les versions bêta d'Active Directory : Lorsque nous avons migré un utilisateur vers une nouvelle forêt Active Directory, l'utilisateur a perdu l'accès aux ressources de sa forêt d'origine. Cela s'est produit parce que le SID accordé à l'utilisateur dans la nouvelle forêt était différent du SID original de l'utilisateur. Il a donc perdu l'autorisation d'accéder à la ressource.

Steve Grobman (aujourd'hui directeur technique de McAfee) a proposé à Microsoft l'idée d'un attribut qui contiendrait le SID original de la forêt source, ce qui permettrait de conserver l'accès aux ressources originales. Microsoft a accepté cette demande de modification de la conception et l'attribut **siIDHistory** est né. Au cours de tout projet de migration ou de consolidation d'Active Directory, l'attribut **siIDHistory** est essentiel pour maintenir l'accès des utilisateurs aux ressources de la forêt source lorsque l'utilisateur a migré vers la forêt de destination mais que les ressources n'ont pas migré.

Cependant, une fois le projet de migration ou de consolidation terminé, **siIDHistory** doit être supprimé. Un acteur de la menace disposant de droits élevés pourrait tirer parti de **siIDHistory** pour copier un SID d'un domaine de confiance (par exemple le SID d'un membre du groupe Domain Admins) et l'ajouter à l'attribut siIDHistory d'un principal de sécurité dans le domaine de confiance, ce qui conférerait à l'attaquant des droits d'administrateur dans le domaine de confiance.

C'est là que le filtrage des SID entre en jeu. Il supprime tous les SID étrangers (c'est-à-dire ne provenant pas du domaine local) du jeton d'accès de l'utilisateur, empêchant ainsi cette attaque par escalade. **Le filtrage SID doit être activé sur tous les trusts de la forêt, à moins qu'un processus de migration ou de consolidation ne soit en cours**.

Malheureusement, d'après mon expérience, la plupart des projets de migration et de consolidation ne se terminent jamais vraiment. Ils s'arrêtent simplement pendant la phase plus difficile de migration des applications, et l'historique des SID reste activé pour que les utilisateurs puissent continuer à accéder à leurs ressources d'origine.

Sachez que certaines erreurs de configuration peuvent réduire l'efficacité des SID. Par exemple :

- Les trusts forestiers sortants dont l'indicateur **TRUST_ATTRIBUTES.TREAT_AS_EXTERNAL** est défini sur true traitent un trust inter-forêts vers un domaine comme un trust externe, ce qui relâche le filtrage plus strict effectué sur les trusts inter-forêts.
- Les accords de confiance comportant l'ensemble d'attributs **TRUST_ATTRIBUTES.CROSS_ORGANIZATION_ENABLE_TGT_DELEGATION** ou **TRUST_ATTRIBUTES.PIM_TRUST** permettent de déléguer un ticket Kerberos, ce qui réduit la protection offerte par le filtrage SID.

12. Surveiller Active Directory pour détecter les activités suspectes et les configurations non sécurisées.

Les attaques exploitent souvent des configurations qui leur permettent d'élever rapidement leurs privilèges et de persister dans votre environnement sans être détectés. C'est pourquoi il convient d'auditer et de surveiller régulièrement les droits d'accès afin de détecter tout signe indiquant qu'une attaque est en cours ou que votre organisation est vulnérable à une attaque.

Certains objets, comme l'objet **AdminSDHolder**, sont rarement modifiés de manière légitime. L'objet **AdminSDHolder** sert de modèle de permissions pour les groupes et les comptes protégés dans un domaine. Si l'héritage est activé, un attaquant peut essayer de modifier les autorisations sur les objets privilégiés contrôlés par **AdminSDHolder**.

Les administrateurs doivent savoir qu'une modification a été apportée et être en mesure d'en expliquer les raisons. Si la modification n'était pas intentionnelle, la probabilité de compromission est élevée. La surveillance de ce type d'activité est essentielle pour détecter rapidement les attaques et empêcher l'exploitation des paramètres.

Comment Semperis peut vous aider à sécuriser Active Directory

Semperis propose des solutions d'évaluation et de restauration de la sécurité de l'Active Directory pour vous aider à concentrer vos efforts.

- L'outil gratuit d'évaluation de la sécurité **Purple Knight** analyse les environnements Active Directory. Entra ID (anciennement Azure AD) et Okta afin d'identifier rapidement les vulnérabilités dans les environnements d'identité hybrides et de fournir des conseils de remédiation experts et hiérarchisés.
- Directory Services Protector (DSP)** permet d'évaluer la sécurité d'Active Directory, de **revenir automatiquement sur les modifications suspectes apportées à Active Directory**, et bien plus encore.
- Active Directory Forest Recovery (ADFR)** **accélère la récupération d'Active Directory de 90 %** par rapport à une récupération manuelle.
- Notre **outil Migrator for AD et nos services de migration experts** prennent en charge les trois phases critiques de tout projet de consolidation, de migration ou de modernisation d'Active Directory : la préparation, l'exécution et le contrôle post-migration.
- Les **experts** de Semperis peuvent vous aider à examiner et à analyser votre architecture et vos configurations de sécurité, vos procédures opérationnelles et les voies d'attaque potentielles. Nous pouvons fournir une feuille de route pour les améliorations de sécurité recommandées ainsi que des plans de remédiation et de récupération.

La protection d'Active Directory peut sembler une tâche monumentale. En adoptant les meilleures pratiques en matière de sécurité d'Active Directory, vous pouvez élever le niveau de difficulté pour les attaquants et améliorer la posture de sécurité globale de votre environnement.

En savoir plus sur les meilleures pratiques en matière de sécurité Active Directory

- Sécurité d'Active Directory : Principaux risques et meilleures pratiques**
- Conseils pour la protection d'Active Directory**
- Guide essentiel pour la sécurisation d'Active Directory**
- Le b.a.-ba de la sécurité AD : Sécurité des contrôleurs de domaine**

S'inscrire pour recevoir les actualités de Semperis

Email Address

By submitting, you agree that Semperis may send you information regarding its products and services, and use and process your personal information in accordance with Semperis' Privacy Policy. You can opt out at any time by contacting privacy@semperis.com.

This site is protected by reCAPTCHA and the Google [Data Policy](#) and [Terms of Service](#) apply.

détection et résolution des menaces AD

Directory Services Protector →

Reprise après sinistre d'AD

Active Directory Forest Recovery →

Pourquoi Semperis

Visite de la plateforme

Nos clients

Ressources

Blog

Études de cas

Glossaire de la sécurité de l'identité

Rapports

Vidéos

Livres blancs

Semperis

À propos de nous

Carrières

Événements

La vie à Semperis

FAQ

Support

Détection des schémas d'attaque

Protection de l'identité de la DSP au moment de

Migra

Migra et consolidation d'AD en toute sécurité

Migrator for Active Directory →

Évaluation de la posture de sécurité de l'identité en ligne

Sauvegarde et récupération des ressources Entra ID

Reprise après sinistre pour Entra Tenant →

Solutions

Migra et consolidation AD

Réduction de la surface d'attaque AD

Analyse du chemin d'attaque

Détection et gestion des menaces AD

Sauvegarde et récupération AD

Audit des modifications AD et retour en arrière

Services Sécurité et récupération des identités

Réponse aux incidents

Analyse légale des violations d'Active Directory

Secteur

Infrastructures critiques

Infrastructures critiques

Services financiers

Santé

Assurance

Secteur public

Vente au détail

Transport

Partenaires

Aperçu des partenaires

Partenaires technologiques stratégiques

Trouver un partenaire

Devenir partenaire

Dans la presse

Récompenses

Communiqués de presse

Dans l'actualité

Demandez une démonstration

Vous êtes victime d'une violation ?

Sécurité d'Active Directory